

F14 · Personal

Rutas: /personal Rol requerido: Gerente Modo probado: Supabase real (pasada B) Fecha: 20/08/2026

Infraestructura: Edge Function manage-staff v3, ACTIVE

Qué hace

- Lista los accesos internos del café con **nombre, usuario, rol y estado**, y tres indicadores en cabecera: personal activo, gerentes y PIN restablecidos.
- **Crea un acceso** con nombre completo, usuario, rol (barista o gerente) y PIN inicial de 6 a 8 dígitos. El usuario se normaliza solo a minúsculas, números, puntos y guiones.
- **Restablece el PIN** de cualquier empleado. El PIN anterior deja de funcionar en el acto y el nuevo entra sin más trámite.
- **Desactiva y reactiva** accesos. Un acceso desactivado no puede volver a entrar: la pantalla responde «Este acceso está desactivado.»
- Comprueba el rol **en dos capas independientes**: la pantalla vive dentro de ManagerOnly, y la Edge Function repite la comprobación en el servidor y responde **403 · «Sólo gerencia puede administrar personal.»** Saltarse la interfaz no sirve de nada.
- Deja rastro en audit_log: cada alta y cada restablecimiento se registran con la acción, el empleado afectado y **quién lo hizo**.
- Valida el PIN en dos capas: el campo impide teclear cualquier cosa que no sea un dígito, y el servidor rechaza los formatos inválidos con «El PIN debe ser numérico, de 6 a 8 dígitos.»
- No permite duplicar un usuario existente, y lo dice en español y hablando de lo que el gerente escribió: «Ya existe un acceso con ese usuario. Elige otro nombre de usuario.»

Qué NO hace

- **Desactivar un acceso no cierra las sesiones ya abiertas** (hallazgo F14-02, severidad alta). Sólo impide entrar de nuevo. Ver el recuadro de riesgos al final: es lo más importante de esta ficha.
- **No permite cambiar el rol de nadie** (hallazgo F14-04). Quien se da de alta como barista se queda barista. El selector de rol existe sólo en el alta.
- **Restablecer el PIN tampoco cierra la sesión abierta** del empleado (hallazgo F14-03).
- **No hay recuperación de PIN por parte del empleado**. Si alguien olvida el suyo, necesita que gerencia se lo restablezca; no existe autoservicio ni envío por correo.
- **No borra empleados**. La baja es lógica (desactivar), nunca física, para no romper la trazabilidad de lo que esa persona hizo.
- El indicador «PIN restablecido» cuenta **todos** los restablecimientos registrados, no los del día ni los de un empleado concreto.

Resultado de las pruebas

CASO PROBADO	RESULTADO OBTENIDO	ESTADO	COMPROBADO EN
P0. La Edge Function está desplegada	manage-staff v3, ACTIVE, verify_jwt: true	Correcto	Panel de Supabase
P1. La lista muestra las cuatro columnas	Nombre, usuario, rol y estado de cada acceso, más los tres indicadores	Correcto	Pantalla
P2. Crear un empleado con rol barista	Aparece en la lista; «Personal activo» sube de 1 a 2 y «Gerentes» se queda en 1	Correcto	Pantalla y staff_profiles
P3. Entrar con el usuario nuevo	Entra como barista, sin menú de «Gestión». Las seis rutas de gestión tecleadas a mano redirigen a /inicio; la Edge Function le responde 403	Correcto	Sesión real de barista
P4. Crear un usuario duplicado	No lo crea, y el aviso es claro y en español	Corregido	Pantalla · F14-01
P5. PIN inválido (no numérico, corto, vacío)	Imposible teclear letras; el servidor rechaza el PIN corto y no crea nada	Correcto	Pantalla y servidor
P6. Restablecer el PIN	El PIN viejo se rechaza con «Usuario o PIN incorrectos.»; el nuevo entra	Correcto	Sesión real
P7. El contador de restablecimientos sube	De 0 a 1, sin recargar. audit_log trae la fila reset_pin con su autor	Correcto	Pantalla y audit_log
P8. Desactivar el acceso	El mensaje al intentar entrar es el esperado, pero la sesión que ya estaba abierta sigue operando	Hallazgo	F14-02
P9. Reactivar el acceso	Vuelve a entrar con el mismo PIN, mismo rol, sin trámite adicional	Correcto	Sesión real
P10. Cambiar el rol de barista a gerente	No se puede hacer desde la aplicación	Hallazgo	F14-04
P11. Desactivar la propia cuenta del gerente	No verificado , excluido a propósito por el responsable	Sin probar	Ver riesgos
Extra. ¿Puede un barista ascenderse solo?	No. La RLS le devuelve 0 filas cambiadas y sólo le deja leer su propia ficha	Correcto	Sesión real de barista

Funcionalidades conectadas verificadas

FUNCIONALIDAD	EFEECTO COMPROBADO	ESTADO
F13 · Reportes	La columna «Empleado» del detalle auditable y de la tabla de Incidencias toma los nombres de staff_profiles, no de un literal; el filtro por empleado los ofrece	Correcto
F01 · Acceso y roles	El rol se respeta en las dos capas: redirección en el cliente y 403 en el servidor, comprobado con el token real de un barista	Correcto

FUNCIONALIDAD	EFEECTO COMPROBADO	ESTADO
Auditoría	audit_log recibe create_staff y reset_pin con el identificador de quien las ejecutó	Correcto

Pruebas automatizadas

- `src/lib/supabase.test.ts` — 7 casos. Cubren la normalización del usuario al correo interno, incluido el caso de seguridad de que un usuario no pueda escaparse del dominio del café.
- No se añadieron pruebas de formato de PIN a propósito: esa regla no vive en el cliente. El campo impide teclear lo que no sea un dígito y la validación real está en la Edge Function, que es código Deno fuera del alcance de esta suite. Duplicar allí una expresión regular que nunca se ejecuta daría una falsa sensación de cobertura.

Limitaciones conocidas y riesgos para la entrega

- **Desactivar un acceso no lo revoca de verdad (F14-02, alta).** Impide entrar de nuevo, pero no toca las sesiones ya abiertas. Comprobado: con el acceso ya desactivado, la sesión abierta siguió leyendo pedidos, reservó un folio de la secuencia del servidor y sobrevivió a recargar la página entera. **Si se despidió a alguien, desactivar su acceso no basta:** hay que cerrar la sesión en cada dispositivo donde estuviera dentro. La solución de fondo pide revalidar el estado del empleado al restaurar la sesión y exigirlo también en las políticas del servidor.
- **No se puede ascender ni degradar a nadie (F14-04, media).** Para cambiar el rol de una persona hay que crear un acceso nuevo y desactivar el viejo, lo que le cambia el nombre de usuario y parte en dos su historial de auditoría. La columna sí es escribible por gerencia, así que exponerlo en la tarjeta del empleado no exige tocar el servidor.
- **Restablecer un PIN no expulsa al que ya está dentro (F14-03, media).** Importa si el PIN se restablece porque se ha comprometido, no si fue un olvido.
- **Riesgo no verificado:** no se probó qué ocurre si el único gerente se desactiva a sí mismo, por decisión expresa del responsable — de permitirse, el negocio se quedaría sin ningún acceso de gerencia y habría que recuperarlo desde Supabase. A favor: el botón de desactivar aparece inhabilitado sobre la propia cuenta, así que la interfaz sí lo impide. **No se ha comprobado si el servidor lo impide igualmente.**
- El alta de un acceso exige fijar un PIN, es decir crear una credencial real. Durante esta revisión esos pasos los ejecutó el responsable del proyecto, no el equipo de verificación.